

Cyber-Sicherheitsbedürfnisse, Angreifer, Angriffsvektoren & Phishing | Basis: KITZ IT-Sicherheit und Datenschutz, Notebooks 001 & 002

Die drei Begriffe werden oft synonym verwendet, beschreiben aber unterschiedlich weite Sicherheitskontexte. Vom Allgemeinen ins Spezielle: **Cyber-Sicherheit** $\supset$ **IT-Sicherheit** $\supset$ **Informationssicherheit**. Cyber-Sicherheit ist also der weiteste Begriff und wird im Modul standardmäßig verwendet.

Merke: Im Modul wird der allgemeinere Begriff **Cyber-Sicherheit** verwendet, weil er den umfassendsten Sicherheitskontext abdeckt. **Kontext:** Schäden in Deutschland jährlich in dreistelliger Milliardenhöhe durch Diebstahl, Spionage, Sabotage.

Definition: Cyber-Sicherheitsbedürfnisse (auch: Cyber-Sicherheitsziele oder Schutzziele) sind die **Grundwerte der Cyber-Sicherheit**. Sie werden durch den Einsatz von **Cyber-Sicherheitsmechanismen** erreicht.

Die Bedürfnisse 1–3 bilden die klassische **CIA-Triade** (Confidentiality, Integrity, Availability). Die Bedürfnisse 4–7 sind moderne Ergänzungen, gelten aber als gleichwertig wichtig.

★ Klausur-Reflex: Wenn nach den *drei klassischen* Schutzziele gefragt wird, antworte mit Vertraulichkeit, Integrität, Verfügbarkeit (CIA). Bei den *erweiterten* Schutzziele kommen Authentifikation, Authentizität, Verbindlichkeit, Anonymisierung dazu.

Authentifikation vs. Authentizität (häufig verwechselt): Authentifikation prüft die *Identität einer Entität* (bist du wirklich du?). Authentizität prüft die *Echtheit von Daten und ihrem Ursprung* (stammt diese Nachricht wirklich von dir und ist sie unverändert?).

3 Motivationen von Angreifern

Ein **Angreifer** versucht gezielt und absichtlich, auf ein IT-System zuzugreifen, um an Informationen zu gelangen, die nicht für ihn bestimmt sind, Aktionen auszulösen, die er nicht auslösen darf, oder Ressourcen zu nutzen, die er nicht nutzen darf. Die Beurteilung des Angriffspotenzials erfordert das Verständnis der Motivation.

Motivation	Kurzbeschreibung
Finanzieller Gewinn	Erpressung (Ransomware), Zugriff auf Bankdaten, Diebstahl von Zahlungsinformationen.
Sabotage	Bewusste Schädigung eines Unternehmens, um sich Wettbewerbsvorteile zu verschaffen.
Spionage	Unternehmens-, militärische oder staatliche Spionage. Meist über längere Zeiträume.
Staatliches Interesse	Mischung aus finanziellen, politischen Motiven, Industriespionage, Terrorabwehr, Strafverfolgung.
Politische Motivation	Gesellschaftlichen Einfluss erlangen: Verschwörungstheorien, Stimmungsmache, Fake News.
Reputation	Demonstration der eigenen Fähigkeiten. „Look what I can do.“
Sicherheitstests	Legitimes Testen, welche Schwachstellen ein IT-System aufweist.
Trolling	Reiner Spaß an der Verletzung der Sicherheitsbedürfnisse anderer.
Whistleblowing	Aufdeckung von Missständen, oft mit ethischer Begründung.
Herausforderung an der Technik	Eigener Antrieb, ein System zu kompromittieren oder ein Botnetz aufzubauen.
Eifersucht, Rache, Kontrollzwang	Stalking, Kontrolle über andere ausüben wollen.
Angst schüren, Spaltung	Terrorismus: gezielte Destabilisierung einer Gesellschaft.

4 Angreifer-Kategorien

Kategorie	Kurzbeschreibung
Hacker	Personen, die in IT-Systeme und Netzwerke eindringen. Klassifikation nach Hutfarbe: White-Hat (legal, ethisch), Black-Hat (kriminell), Gray-Hat (Grauzone zwischen illegalem Angriff und Sicherheitstest).
IT-Spione	Staatlich angestellte Personen, die langfristig Informationen sammeln.
IT-Terroristen	Aus staatlichem Interesse oder im Auftrag von Terrororganisationen handelnd.
Cyber-Kriminelle	Professionelle Berufskriminelle. Häufigstes Motiv: finanzielles Interesse.
Vandalen	Beispiele: Lizard Squad, LulzSec, Anonymous, Derp-Trolling. Motiv häufig „for the lulz“ oder politisch-aktivistisch.
Penetration Tester	Von Firmen beauftragte Sicherheitstester (White-Hats). Häufig organisiert als Red-Team (greift an) gegen Blue-Team (verteidigt).
Behördenmitarbeiter	Alle Arten staatlich durchgeführter Angriffe (Geheimdienste, Strafverfolgung).
Insider	Mitarbeiter mit legitimen Zugriffsrechten auf sensible Daten (z. B. Administratoren). Besonders gefährlich, weil Zugang bereits besteht.

5 Angriffsvektoren

Definition: Ein **Angriffsvektor** bezeichnet sowohl einen *Angriffsweg* als auch eine *Angriffstechnik*, mittels derer ein Angreifer einen erfolgreichen Angriff auf ein IT-System oder einen IT-Dienst durchführt.

★ Klausur-Reflex: Diese Definition ist prüfungsrelevant. Beide Aspekte nennen: Weg UND Technik.

Typische Angriffsvektoren im Überblick

Angriffsvektor	Beschreibung
----------------	--------------

Phishing	Gefälschte E-Mails, Webseiten oder Kurznachrichten geben sich als vertrauenswürdiger Partner aus. Ziel: Erschleichen von Zugangsdaten oder Auslösen einer schädlichen Aktion.
Man-in-the-Middle (MitM)	Abhören und gegebenenfalls Manipulation des Kommunikationskanals zwischen zwei Parteien A und B. Der Angreifer schaltet sich unbemerkt dazwischen.
Clickjacking	Unsichtbare Schaltflächen mit verstecktem Link, die über sichtbaren Elementen liegen. Nutzer klickt etwas anderes, als er glaubt.
DDoS-Angriff	Gezielte Überlastung eines Systems durch übermäßige Anfragen, häufig aus einem Botnetz. Verletzt direkt die Verfügbarkeit.
Timing-Angriff	Physischer Zugriff auf einen Mikrocontroller. Durch gezielte Belegung der Eingangspins nach bestimmten Mustern wird die Funktionalität manipuliert.
Angriff über Peripheriegeräte	USB-Sticks, Kabel, Motoren mit selbstinstallierender Malware. Beim Einstecken in den PC wird der Angriff automatisch aktiviert (Beispiel: BadUSB).
Insider-Bedrohung	Angriffe über bereits vorhandene Zugangsdaten oder Berechtigungen. Klassische technische Schutzmaßnahmen greifen oft nicht.
Multivektor-Angriff	Mehrere Angriffsvektoren werden gleichzeitig oder verkettet genutzt. Häufig bei fortgeschrittenen Angriffen (APT).

6 Phishing im Detail

Definition und Herkunft

Phishing ist ein Neologismus und Kompositum aus „*fishing*“ (engl. für Angeln) und „*phreaking*“ (für Hacken, ursprünglich aus dem Telefonnetz-Hacking). Phishing bezeichnet Täuschungsversuche, sich über gefälschte Webseiten, E-Mails oder Kurznachrichten als vertrauenswürdiger Kommunikationspartner in einer elektronischen Kommunikation auszugeben.

Ziel des Betrugs: An persönliche Daten eines Internet-Benutzers gelangen, etwa durch Login auf einer gefälschten/nachgebauten Webseite, um **Passwort, Benutzername und ggf. den zweiten Faktor** der 2-Faktor-Authentifizierung zu erschleichen.

Verletzte Schutzziele

Phishing zielt primär auf die Verletzung von **Authentifikation** (Identitätsdiebstahl) und **Vertraulichkeit** (Zugangsdaten gelangen in fremde Hände). Bei erfolgreichem Angriff sind häufig auch **Integrität** und **Verbindlichkeit** betroffen, weil der Angreifer im Namen des Opfers handelt.

Phishing-Varianten

Variante	Beschreibung
Massen-Phishing	Massenhafter Versand identischer E-Mails. Niedrige Erfolgsquote, aber durch Skalierung wirksam.
Spear-Phishing	Gezielter Angriff auf eine konkrete Person mit personalisierten Inhalten.
Whaling	Spear-Phishing gegen hochrangige Ziele (CEO, CFO, Vorstand).
Smishing	Phishing per SMS oder Messenger.
Vishing	Voice-Phishing: Angriff per Telefon, oft kombiniert mit Caller-ID-Spoofing.
Clone-Phishing	Eine legitime E-Mail wird kopiert und mit schädlichen Links/Anhängen erneut versendet.

Erkennungsmerkmale (Red Flags)

- **Absender-Adresse:** Domain prüfen. Tippfehler-Domains (amaz0n.com), generische Mail-Provider statt Firmen-Domain, ungewöhnliche Subdomains.
- **Dringlichkeit und Drohung:** „Konto wird in 24h gesperrt“, „Letzte Mahnung“, „Sofortige Aktion erforderlich“. Typischer Druckaufbau.
- **Generische Anrede:** „Sehr geehrter Kunde“ statt persönlicher Anrede mit Namen.
- **Verdächtige Links:** Maus über den Link halten (ohne Klick) und Ziel-URL prüfen. URL-Verschleierung durch Subdomains („paypal.example-attacker.com“) oder URL-Shortener.
- **Rechtschreibung und Grammatik:** Sprachliche Fehler, falsche Formatierung, inkonsistente Sprache. Mit moderner KI nimmt dieses Merkmal allerdings ab.
- **Unerwartete Anhänge:** Insbesondere .zip, .exe, .iso oder Office-Dokumente mit Makros. Niemals ungeprüft öffnen.
- **Inkonsistenter Kontext:** E-Mails von Diensten, die man nicht nutzt; angebliche Bestellungen, die nicht getätigt wurden.
- **Aufforderung zur Eingabe sensibler Daten:** Seriöse Anbieter fordern niemals Passwörter oder vollständige Kreditkartendaten per E-Mail.

Schutzmaßnahmen

- **Technische Filter:** Spam-Filter, SPF/DKIM/DMARC zur Absenderprüfung.
- **Multi-Faktor-Authentifizierung (MFA):** Selbst wenn Passwort gestohlen wird, ist der Account weiterhin geschützt.
- **Awareness-Schulungen:** Mitarbeiter sensibilisieren. Häufig der wirksamste Hebel.
- **URL-Prüfung manuell:** Im Zweifel die Domain manuell im Browser eingeben statt zu klicken.
- **Verdacht melden:** Verdächtige Mails an interne IT oder offizielle Stellen weiterleiten (z. B. BSI in Deutschland).

7 Klausur-Cheatsheet (Last-Minute-Repetition)

Die 7 Schutzziele in einer Zeile

Vertraulichkeit | Integrität | Verfügbarkeit (= CIA-Triade)

Authentifikation | Authentizität | Verbindlichkeit | Anonymisierung/Pseudonymisierung

Schutzziel-zu-Mechanismus-Mapping

Schutzziel	Typischer Mechanismus
Vertraulichkeit	Verschlüsselung, Steganografie
Integrität	TLS/SSL, IPSec, Hash-Funktionen
Verfügbarkeit	Backups (3-2-1), Anti-DDoS, Redundanz
Authentifikation	Biometrie, Passwörter, MFA
Authentizität	Digitale Signaturen, PKI, Blockchain
Verbindlichkeit	Zeitstempel-Services, Blockchain
Anonymisierung	TOR, Pseudonyme, Anonymisierungsverfahren

Definitionen, die du wortwörtlich draufhaben solltest

- **Cyber-Sicherheitsbedürfnisse** sind die Grundwerte der Cyber-Sicherheit. Sie werden auch als Cyber-Sicherheitsziele bezeichnet und durch Cyber-Sicherheitsmechanismen erreicht.
- **Angriffsvektor** bezeichnet sowohl einen Angriffsweg als auch eine Angriffstechnik, mittels derer ein Angreifer einen erfolgreichen Angriff auf ein IT-System oder einen IT-Dienst durchführt.
- **Phishing** bezeichnet Täuschungsversuche, sich über gefälschte Webseiten, E-Mails oder Kurznachrichten als vertrauenswürdiger Kommunikationspartner auszugeben, um an persönliche Daten oder Zugangsdaten eines Nutzers zu gelangen.
- **Angreifer:** versucht gezielt und absichtlich, auf ein IT-System zuzugreifen, um an Informationen zu gelangen, Aktionen auszulösen oder Ressourcen zu nutzen, die nicht für ihn bestimmt bzw. erlaubt sind.

Schnell-Mnemonik

CIA = Confidentiality, Integrity, Availability. Die OG-Triade. Merke: „Was geheim ist, was echt ist, was erreichbar ist.“

Erweiterte 4: **A-A-V-A** = Authentifikation, Authentizität, Verbindlichkeit, Anonymisierung. Merke: „Wer bist du, ist es echt, kannst du's leugnen, bleibst du unerkannt?“

Quellenbasis: Notebooks KITZ_IT-Sicherheit_und_Datenschutz_001 & 002. Inhaltliche Grundlage: Norbert Pohlmann, *Cyber-Sicherheit*, Springer Vieweg, 2022. Diese Zusammenfassung dient ausschließlich der persönlichen Klausurvorbereitung.